

Sql Injection

Solo para laboratorios autorizados. Sustituye variables, confirma versión y guarda salida.

Decisión rápida

1. Confirma alcance, identidad y conectividad.
2. Parte de una señal; no ejecutes toda la tabla.
3. Predice salida y prepara un control negativo.
4. Ejecuta la prueba menos intrusiva.
5. Registra evidencia y vuelve al módulo si falla.

Señales

- Una comilla simple ' provoca un error de SQL o una pagina en blanco/500.
- Payloads logicos cambian el resultado: ' OR '1'='1 devuelve mas filas o entra sin password.

Comandos y pruebas

Prueba	Objetivo/contexto	Evidencia esperada
'	Prueba de deteccion: una sola comilla rompe la sintaxis si el campo es inyectable.	Un error de SQL o una pagina 500 = probable SQLi. Si no cambia nada, prueba comilla doble o la version numerica (sin comillas).
' OR '1'='1	Bypass de login clasico: cierra la cadena y fuerza una condicion siempre verdadera.	Entras sin credenciales validas, o la busqueda devuelve todas las filas.

Diagnóstico

Síntoma	Comprobar
Sin respuesta	ruta, DNS, puerto, listener y firewall
Rechazo	sintaxis, credenciales, permisos y versión
Salida distinta	control negativo, caché y estado
Resultado parcial	identidad efectiva y precondiciones

Cierre

- Guardar comando adaptado y salida.
- Anotar qué confirma y qué no.
- No persistir secretos en notas compartidas.
- Restaurar cambios del laboratorio.

Fuente operativa: conceptos de Fieldbook. Método: construcción de payloads.